

OSINT (Open Source Intelligence)

OSINT is the umbrella discipline that everything you've studied recently — WHOIS, DNS/subdomain enum, Google/GitHub Dorking, email enumeration — actually falls under. It's the practice of collecting and analyzing publicly available information to build intelligence about a target, without ever directly interacting with (or touching) their systems. This guide ties those individual techniques together into the bigger picture.

1. What Makes Information "OSINT"

OSINT specifically means information that is:

- **Publicly accessible** — no hacking, no authentication bypass, no exploiting anything to get it
- **Legally obtainable** — anyone could find it through normal means (search engines, public records, social media)
- **Passive by nature** — you're observing/collecting, not actively probing a target's live systems

This is what separates OSINT from active reconnaissance (like Nmap scanning) — OSINT carries essentially zero legal/detection risk because you're never touching the target's actual infrastructure.

2. The OSINT Framework — Categories

Security-focused OSINT typically breaks into these categories:

Category	What It Covers	Examples of Sources
Domain/Infrastructure OSINT	Domains, subdomains, IPs, hosting, DNS	WHOIS, DNS records, crt.sh, Shodan
People OSINT	Employees, roles, org structure	LinkedIn, company "About" pages
Email OSINT	Valid email addresses, naming conventions	theHarvester, Hunter.io

Category	What It Covers	Examples of Sources
Social Media OSINT	Public posts, connections, metadata	Twitter/X, LinkedIn, Facebook, Instagram
Code/Repository OSINT	Leaked secrets, internal tooling	GitHub Dorking, GitLab, Bitbucket
Document OSINT	Metadata in public PDFs/docs (author names, software versions, internal paths)	Google Dorking (<code>filetype:pdf</code>), <code>exiftool</code>
Breach Data OSINT	Whether emails/credentials appear in known breaches	HavelBeenPwned, DeHashed
Technical Footprint OSINT	Exposed devices/services on the internet	Shodan, Censys, ZoomEye
Geolocation OSINT	Physical location from images/metadata	EXIF data, reverse image search

You've already gone deep on the first three rows in earlier sessions — this guide is really about connecting them and filling in the categories you haven't covered yet.

3. The OSINT Cycle (How Professionals Structure This Work)

OSINT isn't just "search around randomly" — intelligence work follows a repeatable cycle, borrowed from traditional intelligence tradecraft:

1. Planning & Direction → What do I need to know? (define scope/objectives)
2. Collection → Gather raw data from sources
3. Processing → Organize/filter the raw data
4. Analysis → Find patterns, connections, actionable insight
5. Dissemination → Report findings (to a client, a SOC, yourself)

For a pentest engagement, this maps directly onto the reconnaissance section of your report: **Planning** = agreeing scope with the client, **Collection** = running WHOIS/theHarvester/dorking, **Processing** = deduplicating and validating what you found, **Analysis** = deciding what's actually exploitable or worth pursuing, **Dissemination** = the recon section of your final report.

4. New Tools/Sources Worth Adding to Your Toolkit

Since you've already covered WHOIS, DNS, Google/GitHub dorking, and email enumeration in depth, here's what completes the picture:

a) Shodan — "The Search Engine for Internet-Connected Devices"

Unlike Google (which indexes web *pages*), Shodan continuously scans the entire internet and indexes **banners** — the raw responses devices give when you connect to a port (SSH banners, HTTP headers, industrial control system responses, webcam feeds, etc.).

```
# Web interface
https://www.shodan.io/search?query=apache+country:IN

# Common search filters
org:"Company Name"
hostname:example.com
port:3389 country:IN          # exposed RDP in India
product:"MongoDB" -authentication
```

```
# CLI (after `pip install shodan` and API key setup)
shodan search "org:'Company Name'"
shodan host 8.8.8.8
```

This is how researchers routinely find exposed databases, ICS/SCADA systems, and misconfigured cloud instances without ever port-scanning the target directly — Shodan already did the scanning, you're just querying its index.

b) Censys — Similar to Shodan, Different Data Model

```
https://search.censys.io/search?resource=hosts&q=services.s
ervice_name:MONGODB
```

Censys is often considered stronger for certificate-based pivoting (finding all hosts sharing a specific TLS certificate — useful for mapping infrastructure that Shodan's search syntax handles less elegantly).

c) Wayback Machine / Archive.org — Historical Website Snapshots

```
https://web.archive.org/web/*/example.com
```

Useful for finding content that's since been removed — old admin panel links, exposed staging environments, employee names/emails from an old "Team" page, or even source code visible in old unminified JS files.

```
# waybackurls - pulls every historical URL Archive.org has  
recorded for a domain  
waybackurls example.com > archived_urls.txt
```

This is a genuinely underrated recon step — organizations forget what they used to expose, but the Wayback Machine doesn't.

d) Metadata Extraction from Public Documents (**exiftool**)

Public PDFs, Word docs, and images on a target's website often leak metadata:

```
exiftool document.pdf
```

Common findings: **author name** (real employee username), **software version** (reveals what tools/OS the org uses internally), **internal file paths** (`C:\Users\jsmith\Documents\...`), and **GPS coordinates** embedded in photos.

Combine with Google Dorking to find the documents first:

```
site:example.com filetype:pdf  
site:example.com filetype:docx
```

e) Breach Data Correlation

```
curl -s "https://haveibeenpwned.com/api/v3/breachedaccount/  
EMAIL" -H "hibp-api-key: YOUR_KEY"
```

Confirms whether harvested emails have appeared in known breaches — a strong signal the account is real/active, and (in an authorized password-

spraying engagement) sometimes reveals password patterns if breach data itself is available on separate breach-lookup platforms.

f) Social Media OSINT

- **LinkedIn** — org structure, job titles, tech stack hints from job postings (you already used this angle in email enumeration)
- **Twitter/X, Instagram** — geolocation clues, personal info useful for social engineering pretexts
- **Job postings themselves** — often the single best source for an org's actual tech stack ("Experience with Splunk, CrowdStrike, and AWS required" tells you exactly what a red teamer needs to prepare for)

g) **theHarvester** and **Recon-ng** — Aggregators

theHarvester you've already used for email/subdomain harvesting. **Recon-ng** is a more full-featured OSINT framework (Metasploit-style modular console) that chains multiple OSINT sources — WHOIS, Shodan, breach data, social media — into one workflow with a persistent workspace/database.

```
recon-ng
> workspaces create target_recon
> marketplace install all
> modules load recon/domains-hosts/hackertarget
> options set SOURCE example.com
> run
```

h) SpiderFoot — Automated OSINT Aggregation

```
spiderfoot -l 127.0.0.1:5001
```

Runs 200+ OSINT modules automatically (WHOIS, DNS, breach data, Shodan, dark web mentions, etc.) and correlates results into a single report — the closest thing to "run one tool, get a full OSINT report" in this space.

5. Putting the Full Picture Together — A Real OSINT Workflow

This chains everything you've studied across this whole series into one coherent engagement flow:

```
1. WHOIS                → registrar, name servers, IP ownership
2. DNS enumeration      → A/MX/TXT/NS records, zone transfer check
3. Subdomain enumeration → crt.sh, Amass, gobuster (passive + active)
4. Google Dorking       → exposed files, login portals, misconfig
5. GitHub Dorking       → leaked secrets, internal repos
6. Email enumeration    → theHarvester, Hunter.io, LinkedIn naming patterns
7. Shodan/Censys        → exposed services/devices on discovered IPs
8. Wayback Machine      → historical content, forgotten endpoints
9. Document metadata    → exiftool on discovered PDFs/docs
10. Breach data correlation → validate harvested emails against HIBP
11. Social media/job postings → org structure, tech stack, pretexting material
    ↓
Compile into a structured OSINT report → feeds into active recon (Nmap)
and eventually the exploitation phase, if in scope
```

6. OSINT in the Kill Chain / ATT&CK Context

Framework	Mapping
Cyber Kill Chain	Entirely the Reconnaissance stage — OSINT <i>is</i> what "Recon" means in the Kill Chain
MITRE ATT&CK	TA0043 (Reconnaissance) as a whole tactic — covers T1590 (Network Info), T1591 (Org Info), T1593 (Search Open Websites), T1596 (Search Open Technical Databases), T1598 (Phishing for Info)

Worth noting: ATT&CK's entire Reconnaissance tactic category is essentially "OSINT, formalized into specific techniques" — every sub-technique under TA0043 maps to something you've now studied individually (DNS = T1590.002, code repos = T1593.003, email addresses = T1589.002, etc.).

7. Legal & Ethical Notes (Reinforcing the Pattern From Earlier Topics)

- OSINT collection itself is legal — you're using public sources the way anyone could
- The same rule applies as with dorking: **collecting** public data ≠ **using** it for unauthorized purposes. Building a phishing target list is fine in an authorized engagement; actually phishing without authorization is not

- Some data sources have their own **Terms of Service** restrictions (e.g., scraping LinkedIn at scale technically violates their ToS even though the data itself is "public") — worth being aware that "legal" and "ToS-compliant" aren't always the same thing, and professional engagements should stay within both
- For OSINT involving individuals specifically (not just organizations), be mindful this can edge into privacy-sensitive territory even when technically legal — professional OSINT work is usually scoped tightly to what's relevant for the assessment, not "everything findable about this person"

8. Defensive Angle — OSINT Awareness for Organizations (SOC Relevance)

Since you're building toward SOC work too, know how organizations reduce their OSINT footprint:

- **Employee social media training** — avoid posting internal tool names, org charts, or "excited to start my new role in IT Security at X" posts that reveal team structure
- **Document metadata scrubbing** — stripping author/internal path metadata before publishing PDFs externally
- **Reducing job posting detail** — vague job postings ("experience with enterprise security tools") leak less tech-stack info than specific ones ("must know Splunk ES, CrowdStrike Falcon, and Palo Alto Panorama")
- **Domain/subdomain hygiene** — decommissioning old subdomains instead of leaving them dangling (ties back to your subdomain takeover notes)
- **Periodic self-OSINT** — running the exact workflow from Section 5 against your own organization is a legitimate, increasingly common practice called **Attack Surface Management (ASM)** — several commercial platforms exist specifically to automate this continuously

Quick Reference Cheat Sheet

```
# Infrastructure/technical footprint
shodan search "org:'Company Name'"
shodan host <IP>
```

```
# Historical content
waybackurls example.com

# Document metadata
exiftool document.pdf

# Breach correlation
curl -s "https://haveibeenpwned.com/api/v3/breachedaccount/
EMAIL" -H "hibp-api-key: KEY"

# Aggregator frameworks
recon-ng
spiderfoot -l 127.0.0.1:5001
```